

## Section 6-1: Cloud Security Configurations

- Security is the main reason for hesitation when moving to the cloud
- This section covers common cloud threats and security tools
- You will learn how to protect networks, compute resources, and data

### Threats to Cloud Security

- Common internal and external threats to cloud security include:
  - Data breaches
  - DoS and DDoS attacks
  - Insecure interfaces
  - Advanced persistent threats (APTs)
  - Account hijacking and poor account management
  - User error
  - Insider threats
  - Data loss without backups

### Scanning Tools (1 of 3)

- Scanning tools improve security by finding insecure ports, software, firmware, and permissions
- They are used intentionally on your own network
- Popular scanning tools include:
  - Nmap
  - Nessus
  - Metasploit

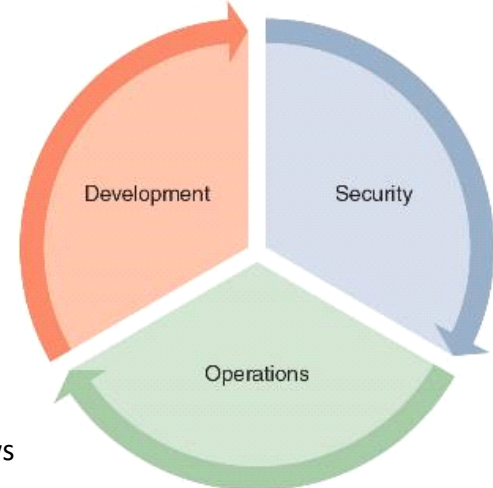
### Scanning Tools (3 of 3)

- Scanning tools can scan deeper if they use **account credentials**, this is called a **credentialled scan**  
*(The tool logs in and finds more security problems)*
- **Network-based scans** scan devices through the network  
*(They check configurations and find security gaps)*
- **Agent-based scans** use small programs installed on devices  
*(Agents collect device data and send it for analysis)*
- A **risk register** is used to record security risks and plans  
*(Includes cybersecurity-background-vulnerability risks, solutions, and responsible people)*

credential =  
kimlik bilgileri

## Cloud-Based Approaches to Security (1 of 2)

- Cloud security follows the **shared responsibility model**  
The cloud provider and the customer share security responsibilities
- Two main approaches to improve cloud security are **DevSecOps** and **micro-segmentation**
- **DevSecOps** 's mantra is “Security is everyone’s responsibility”  
Security is included in development and operations
- **Micro-segmentation** gives more detailed control of cloud traffic and workflows
  - It helps monitor and limit communication between cloud resources
  - It applies security rules to VMs, workloads, and network connections



**Figure 6-3** DevSecOps involves input from all three teams throughout the application's life cycle

## Supporting Shadow IT

- Cloud-hosted applications are the most common part of shadow IT
- Shadow IT can be managed by clear company security policies and user education
- A major concern with shadow IT is protecting regulated data like customers' **PII**
- Company policies should state that regulated data cannot be stored or processed using shadow IT
- Companies should create an approved application list with trusted and reliable tools

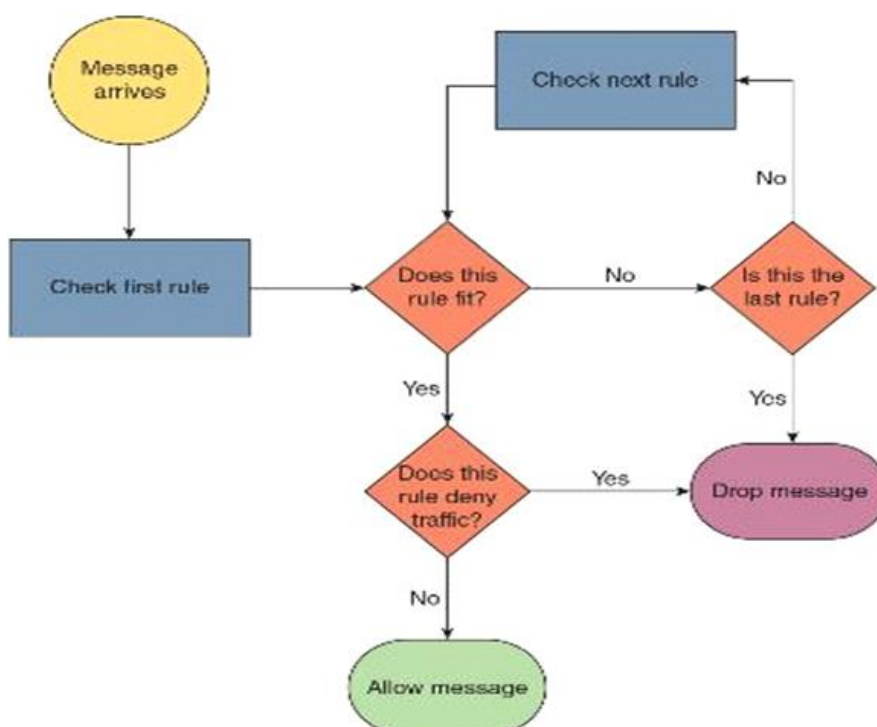
## Virtual Network Security

- A unified cloud security system often uses the CSP's built-in security tools and provides:
  - Fewer compatibility issues
  - Better visibility of cloud infrastructure
  - Centralized monitoring activities
  - Easier and more efficient scaling
- This section covers built-in security tools for cloud resources in AWS, Azure, and GCP

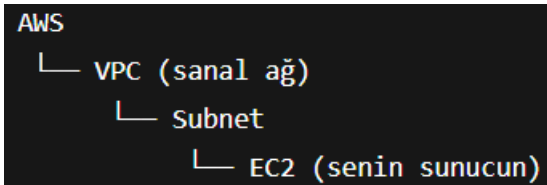
compatibility  
= uyumluluk

## Allow and Deny Rules (1 of 2)

- Cloud platforms provide **built-in** security at the platform level to protect resources
- A common security feature is the use of **allow** and **deny** rules
- These rules check details like port number, protocol, and IP address or CIDR range
- An **allow list** lets traffic pass, while a **block list** or **deny list** stops traffic
- Security rules improve availability because firewalls and backups are managed by the cloud platform



**Figure 6-5** Firewall rules are checked in order of priority to determine whether a message is allowed to pass



## AWS VPCs and Subnets (1 of 4)

- **NAC (network access control)** balances network access and security  
It uses network policies to decide the level and type of access
- A **NACL (network access control list)** allows or blocks traffic into and out of VPC subnets
- NACL characteristics include:
  - NACL rules can **allow or deny traffic**
  - NACL rules are **numbered** and **evaluated by priority**, starting with the lowest number
  - NACL rules are **stateless**, so inbound and outbound traffic are checked **separately**

## AWS VPCs and Subnets (2 of 4)

- **Security Groups**
  - A security group works as a virtual firewall at the host level and controls traffic on a network interface
  - Unlike NACLs, security groups apply to instances(EC2) servers, **not to the subnet**
  - You can attach up to five security groups to one instance
  - Security group rules only **allow** traffic
  - Security group rules are **stateful**, inbound and outbound traffic checked **together**.
  - Rules are checked when traffic tries to enter an instance, and the most specific rule is applied. Security Groups do not evaluate rules in order.

## AWS VPCs and Subnets (3 of 4)

- **Flow Logs**
  - VPC flow logs track traffic that passes through a network interface
  - Log data is sent to CloudWatch Logs or stored in an Amazon S3 bucket
  - These logs don't contain content of packets, just traffic information. IP, port, protocol
- **Traffic Mirroring**
  - Traffic mirroring captures network traffic and gives deeper analysis than flow logs
  - This data can be used to analyze attacks and find vulnerabilities
  - It can also help find the root cause of performance problems

## Azure Virtual Networks (1 of 5)

- Microsoft recommends using a perimeter network in Azure to control and manage Internet traffic to protected resources
- A perimeter network is a subnet in a VNet that acts as a **screened subnet** (or called DMZ) between your private resources and open Internet.
- Azure provides different security devices to protect resources in and across VNets

## Azure Virtual Networks (2 of 5)

- **Network Virtual Appliance (NVA)**
  - An NVA is a virtual machine **in the perimeter network** that controls traffic between the perimeter network and other subnets
  - Third-party NVAs can add extra security features such as:
    - **Firewalling**
    - **IDS / IPS**  
IDS detects suspicious activity and reports it  
IPS actively blocks or reduces the threat
    - **Antivirus**
  - An NVA can control incoming traffic, outgoing traffic, or both  
It can work at OSI layer 4 or OSI layer 7

## Azure Virtual Networks (3 of 5)

- **Network Security Group (NSG)**

- Azure NSG provides firewall-style protection at the subnet level
- Azure creates **six** default rules for each NSG, three for inbound traffic and three for outbound traffic
- Default rules cannot be removed or changed, but they can be overridden with higher-priority rules
- NSG rules are stateful, so once traffic is allowed, related traffic is also allowed

## Azure Virtual Networks (5 of 5)

- **Application Security Group (ASG)**

- An ASG is a subgroup of an NSG and supports micro-segmentation based on application and workload type in the VNet
- You can associate one or more ASGs with each network interface

- Other Azure security tools include:

- Azure Firewall for high availability threat protection
- Azure Network Watcher for capturing and monitoring traffic logs
- Microsoft Defender for Cloud to protect cloud instances from malware
- VNet TAP for network traffic capture and analysis

| Özellik            | Flow Logs | Traffic Mirroring |
|--------------------|-----------|-------------------|
| Trafik özeti       | ✓         | ✗                 |
| Paket içeriği      | ✗         | ✓                 |
| Güvenlik analizi   | Orta      | Çok derin         |
| Performans analizi | Sınırlı   | Detaylı           |

### 4 NACL vs Security Group (net tablo)

| Özellik            | NACL       | Security Group |
|--------------------|------------|----------------|
| Seviye             | Subnet     | Instance       |
| Allow              | ✓          | ✓              |
| Deny               | ✓          | ✗              |
| Stateful           | ✗          | ✓              |
| Kural sırası       | Numara ile | Otomatik       |
| Inbound / Outbound | Ayrı ayrı  | Birlikte       |